Security & Privacy Disclosure, Final Report

Midea mSmartLife (com.midea.ai.overseas)

Two hardcoded Firebase keys route smart-appliance control over unencrypted HTTP, a 122MB virtual-machine-encrypted DEX conceals confirmed Tencent Mars/WeChat infrastructure from independent verification, and five BOOT_COMPLETED receivers pair with background location access to begin tracking before any user interaction, unresolved through 93 days and a 19-day-overdue embargo, with six messages answered by one generic Chinese-language consumer-service auto-reply and zero substantive response

PUBLIC DISCLOSURE, 17 OCTOBER 2026 — EMBARGO REACHED 28 SEPTEMBER 2026, SIX FINDINGS REMAIN UNADDRESSED

Target	Midea Group Co., Ltd. (Foshan, China; SHE: 000333) — owner of KUKA AG (Augsburg, Germany)
Package	com.midea.ai.overseas (mSmartLife)
Platform Audited	Android, static analysis of the production APK (198MB, apktool /dex-strings/manifest/NSC/SDK-fingerprint)
Initial Disclosure (R1)	2026-06-30 (REF MIDEA-MSMARTLIFE-2026)
Disclosure / Embargo Date	2026-09-28
Report Published	2026-10-17
Overall Severity	CRITICAL
Findings	6 (2 Critical, 3 High, 1 Medium)
Correspondence	6 messages sent by RFI-IRFOS to MideaDPO@midea.com and security@midea.com over 62 days; one generic Chinese-language consumer-service auto-reply received (does not engage any finding), zero substantive response ever received
Authorities CC'd	Austrian Datenschutzbehoerde (DSB) (CC) · European Data Protection Supervisor (EDPS) (CC) · German BfDI and Bavarian LDA (BCC, R1 only, given KUKA AG's Augsburg seat)

security@rfi-irfos.com • rfi-irfos.com

ZVR 1015608684 • GISA 39261441 • UID ATU83405245 • Steuernummer 68 696/8736 • Graz, Austria

Contents

1 Executive Summary 4

2 Subject & Operator Context 5

3 Engagement Summary 5

4 Findings 6

4.1 C1: Hardcoded Firebase keys and cleartext HTTP device-control endpoints, including an unencrypted P2P relay port . . . 6

4.2 C2: 122MB virtual-machine-encrypted DEX conceals confirmed Tencent/WeChat infrastructure from independent verification . . . 7

4.3 H1: Five BOOT_COMPLETED receivers paired with background location access begin tracking before any user interaction . . . 8

4.4 H2: Tencent Mars (WeChat networking framework) and Tencent Mobile Framework present as likely transfer path to Chinese infrastructure . . . 8

4.5 H3: Dangerous permission combination with no disclosed purpose: READ_LOGS, QUERY_ALL_PACKAGES, SYSTEM_ALERT_WINDOW, mandatory CAMERA . . . 9

4.6 M1: Tencent QBar computer-vision SDK bundled in assets confirms a third independent Tencent integration point . . . 9

5 Impact Analysis 10

6 The Complete Chain: Six Messages, One Automated Acknowledgment, Zero Substantive Replies 10

7 Data Protection – Article by Article 11

8 Regulatory & Legal Landscape 11

9 Indicators of Compromise 12

10 Disclosure Timeline & Outcome 12

11 Residual Risk & Recommendations 13

Executive Summary

Midea mSmartLife is the companion app for Midea Group's smart home appliances (air conditioners, washing machines, heating). Midea Group Co., Ltd. (Foshan, China; SHE: 000333) is the world's largest household appliance manufacturer by volume and owns KUKA AG, the Augsburg-based industrial robotics manufacturer. A root-level static analysis of the production Android binary (com.midea.ai.overseas, 198MB) found six findings, two CRITICAL, three HIGH, and one MEDIUM.

Two Firebase API keys are hardcoded in the production build alongside a set of cleartext (unencrypted) HTTP endpoints, including the device-control host air.midea.com and an unencrypted P2P relay port, meaning commands to climate and laundry appliances travel over a channel an on-path attacker can observe and potentially alter (C1). Separately, the app's classes.dex is 122MB, roughly ten to sixty times the size of a typical Android app's code, and standard decompilation tooling extracts only 3 classes from it instead of an expected tens of thousands, the signature of virtual-machine-level code encryption. Despite that encryption, residual strings confirm Tencent Mars (WeChat's own cross-platform networking and logging framework), Tencent Mobile Framework, and an explicit WeChat package reference are present and in use, meaning a confirmed People's Republic of China corporate infrastructure dependency has been deliberately placed beyond the reach of the independent verification that GDPR Art. 5(2) accountability presumes is possible (C2). The app also registers five separate BOOT_COMPLETED receivers alongside ACCESS_BACKGROUND_LOCATION, meaning location collection can begin at device startup, before any user interaction or consent screen (H1); carries the Tencent Mars/WeChat networking stack as a likely transfer path to Tencent infrastructure in Shenzhen with no documented Art. 46 safeguard (H2); and declares a permission set (READ_LOGS, QUERY_ALL_PACKAGES, SYSTEM_ALERT_WINDOW, mandatory CAMERA) with no evident justification for an appliance-control app (H3). A Tencent QBar computer-vision SDK bundled in assets confirms a third, independent Tencent integration point (M1).

RFI-IRFOS disclosed these findings on 30 June 2026 to MideaDPO@midea.com and security@midea.com, CC press@midea.com, the Austrian Datenschutzbehoerde, and the European Data Protection Supervisor (BCC to the German BfDI and the Bavarian LDA given KUKA AG's Augsburg seat), stating an embargo date of 28 September 2026. Over the following 62 days RFI-IRFOS sent five further messages restating the findings and the three direct questions. On 31 August 2026 RFI-IRFOS received a single automated reply, a generic Chinese-language consumer-service acknowledgment stating a 15-business-day response window and account-deletion self-service instructions, which does not engage any of the six technical findings. No further response, automated or human, was ever received.

ID	Severity	Title
C1	CRITICAL	Hardcoded Firebase keys and cleartext HTTP device-control endpoints, including an unencrypted P2P relay port
C2	CRITICAL	122MB virtual-machine-encrypted DEX conceals confirmed Tencent/WeChat infrastructure from independent verification
H1	HIGH	Five BOOT_COMPLETED receivers paired with background location access begin tracking before any user interaction

ID	Severity	Title
H2	HIGH	Tencent Mars (WeChat networking framework) and Tencent Mobile Framework present as likely transfer path to Chinese infrastructure
H3	HIGH	Dangerous permission combination with no disclosed purpose: READ_LOGS, QUERY_ALL_PACKAGES, SYSTEM_ALERT_WINDOW, mandatory CAMERA
M1	MEDIUM	Tencent QBar computer-vision SDK bundled in assets confirms a third independent Tencent integration point

Subject & Operator Context

Midea mSmartLife is the companion Android app for Midea Group's smart home appliances, sold across the EU. Midea Group Co., Ltd. (Foshan, China; Shenzhen Exchange: 000333) is the world's largest household appliance manufacturer by shipment volume and the owner of KUKA AG, the Augsburg, Germany-based industrial robotics manufacturer, a detail this report treats as relevant context for the German supervisory-authority notification alongside the Austrian one.

Engagement Summary

RFI-IRFOS sent the initial disclosure on 30 June 2026 to MideaDPO@midea.com and security@midea.com, CC press@midea.com, the Austrian Datenschutzbehoerde, and the European Data Protection Supervisor, BCC the German BfDI and the Bavarian LDA, stating an embargo date of 28 September 2026 under REF MIDEA-MSMARTLIFE-2026. RFI-IRFOS followed up on 6 July, 17 July, 27 July, 9 August, and 31 August 2026, six messages in total, each restating the six findings and the three direct questions. On 31 August 2026, RFI-IRFOS received one automated reply: a generic Chinese-language consumer-service acknowledgment ("we confirm receipt of your email and will respond within no more than 15 business days") that addresses account-deletion self-service steps and does not engage any of the six technical findings. No further reply, automated or human, was ever received. Two early delivery-status notifications recorded a transient bounce on dsb@dsb.gv.at (554 5.7.1) in June and July 2026; the Austrian DSB remained in CC on all subsequent messages.

Findings

C1: Hardcoded Firebase keys and cleartext HTTP device-control endpoints, including an unencrypted P2P relay port

CRITICAL (CVSS v4.0 AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N, 9.3) — appliance control commands travel over an unencrypted channel observable and alterable by any on-path attacker

```
google_api_key: [REDACTED IN PUBLIC REPORT -- disclosed privately to Midea in R1]
google_crash_reporting_api_key: [REDACTED IN PUBLIC REPORT -- disclosed privately to
    Midea in R1]
firebase_database_url: [REDACTED IN PUBLIC REPORT -- disclosed privately to Midea in
    R1]

Cleartext HTTP endpoints (no TLS):
  http://air.midea.com (device control)
  http://airtest.midea.com
  http://weather.midea.com
  pgp2p.midea.com:7781 (unencrypted P2P relay port)
```

Impact: Two Firebase API keys (a general API key and a separately issued crash-reporting key) are hardcoded in the production build with no certificate-fingerprint binding. Alongside them, several device-control and telemetry hosts are reachable over plain, unencrypted HTTP rather than TLS, including air.midea.com, airtest.midea.com, weather.midea.com, and an unencrypted peer-to-peer relay port (pgp2p.midea.com:7781). Commands controlling climate control units, washing machines, and heating appliances travel over this unencrypted channel, meaning an attacker positioned on the same network path can observe and potentially alter device commands in transit.

C2: 122MB virtual-machine-encrypted DEX conceals confirmed Tencent/WeChat infrastructure from independent verification

CRITICAL (CVSS v4.0 AV:N/AC:H/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N, 7.8) — RFI-IRFOS blast-radius escalation: raised from a HIGH-band technical score to CRITICAL because the encryption conceals a confirmed People's Republic of China infrastructure dependency from GDPR Art. 5(2) accountability verification, at the scale of the world's largest appliance manufacturer's EU install base, not because the encryption mechanism itself was exploited

```
classes.dex size: 122,002,416 bytes (typical: 2-15MB)
apktool-decompiled classes: 3 (expected: ~50,000-100,000)

Residual strings confirmed despite encryption:
  Lcom/tencent/tmf/utils/GsonUtils; (Tencent Mobile Framework)
  Lcom/tencent/mars/xlog/Log$LogImp; (Tencent Mars cross-platform framework)
  Lcom/tencent/mars/xlog/Xlog; (Tencent Mars encrypted logging)
  com.tencent.mm (WeChat package reference)
  com.tencent.mm.ui.LauncherUI (WeChat launcher)
  doSetOptionsTencent (x2, explicit Tencent configuration call)
```

Impact: The app's classes.dex is 122,002,416 bytes, far beyond the 2-15MB typical for an Android app of this kind. Standard decompilation (apktool) extracts only 3 classes from it, against an estimated 50,000-100,000 expected, the signature of virtual-machine-level code protection (VMP) of the kind used by Alibaba mPaaS, Tencent Legu, or comparable Chinese obfuscation platforms. Despite the encryption, residual strings confirm the presence and active use of Tencent Mars (WeChat's own cross-platform networking and logging framework), Tencent Mobile Framework utilities, an explicit WeChat package reference (com.tencent.mm), and a Tencent-specific configuration call (doSetOptionsTencent). GDPR Art. 5(2) requires Midea to be able to demonstrate the lawfulness of its processing; an architecture that places its own code beyond independent verification while confirmed third-country infrastructure dependencies remain detectable in the residue is a structural obstacle to that demonstration, at a scale affecting every EU installation of the world's largest household appliance manufacturer's smart home app.

H1: Five BOOT_COMPLETED receivers paired with background location access begin tracking before any user interaction

HIGH (CVSS v4.0 AV:P/AC:L/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N, 6.5) — location collection can begin at device startup, before any consent screen

```
<uses-permission android:name="android.permission.RECEIVE_BOOT_COMPLETED"/>
<uses-permission android:name="android.permission.ACCESS_BACKGROUND_LOCATION"/>

5x <action android:name="android.intent.action.BOOT_COMPLETED"/> (separate receivers)
```

Impact: The manifest registers five separate receivers listening for android.intent.action.BOOT_COMPLETED, alongside the ACCESS_BACKGROUND_LOCATION permission, which allows continuous location collection even when the app is not active. Combined, the app can begin capturing device location from the moment of device startup, before any user interaction and before any consent screen can appear. No disclosed purpose explains why a climate-control and laundry-appliance app needs five independent boot receivers.

H2: Tencent Mars (WeChat networking framework) and Tencent Mobile Framework present as likely transfer path to Chinese infrastructure

HIGH (CVSS v4.0 AV:N/AC:H/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N, 6.9) — confirmed third-country networking infrastructure with no documented Art. 46 safeguard

```
Tencent Mars (WeChat networking/logging framework): present, in use
Tencent Mobile Framework (TMF): present
WeChat package reference (com.tencent.mm): present
Art. 46 GDPR transfer safeguard for this flow: none identified
```

Impact: Tencent Mars is WeChat's own cross-platform networking and logging framework; Tencent Mobile Framework (TMF) is a related enterprise mobile development platform. Both are present and in active use (doSetOptionsTencent is called) in a Midea home-appliance app distributed to EU consumers. Their presence indicates device data, log data, or user data may be processed via Tencent infrastructure in Shenzhen, China, with no Art. 46 GDPR transfer safeguard (Standard Contractual Clauses or equivalent) apparent, and under a jurisdiction where China's National Intelligence Law Art. 7 applies to domestic technology companies.

H3: Dangerous permission combination with no disclosed purpose: READ_LOGS, QUERY_ALL_PACKAGES, SYSTEM_ALERT_WINDOW, mandatory CAMERA

HIGH (CVSS v4.0 AV:P/AC:L/AT:N/PR:L/UI:N/VC:L/VI:L/VA:N/SC:N/SI:N/SA:N, 6.1) — overlay, log-access, and app-enumeration permissions with no evident appliance-control purpose

```
android.permission.READ_LOGS
android.permission.QUERY_ALL_PACKAGES
android.permission.WRITE_SETTINGS
android.permission.SYSTEM_ALERT_WINDOW
android.permission.MOUNT_UNMOUNT_FILESYSTEMS
android.permission.CAMERA (required="true")
android.permission.BLUETOOTH_PRIVILEGED
```

Impact: The manifest declares READ_LOGS (reads other apps' logcat output, including authentication tokens and debug output in some configurations), QUERY_ALL_PACKAGES (enumerates every installed app, a profiling vector), SYSTEM_ALERT_WINDOW (overlay over other apps, a known phishing/clickjacking vector), WRITE_SETTINGS, MOUNT_UNMOUNT_FILESYSTEMS, BLUETOOTH_PRIVILEGED, and a CAMERA permission marked android:required="true", meaning the app cannot be installed on a device without a camera. No disclosed purpose explains why a washing machine and air-conditioning control app needs system log access, full app enumeration, overlay rights, or mandatory camera access.

M1: Tencent QBar computer-vision SDK bundled in assets confirms a third independent Tencent integration point

MEDIUM (CVSS v4.0 AV:N/AC:H/AT:N/PR:N/UI:N/VC:N/VI:N/VA:N/SC:N/SI:N/SA:N, 3.5) — third confirmed Tencent SDK integration, used in WeChat itself

```
assets/qbar/detect_model.bin, detect_model.param (QR/barcode detection ML model)
assets/qbar/srnet.bin, srnet.param (Tencent QBar super-resolution network)
```

Impact: The app bundles Tencent QBar, Tencent's proprietary barcode/QR-scanner SDK (also used in WeChat), including its machine-learning detection models, in the assets/qbar/ directory. This is the third independently confirmed Tencent integration point in the app (alongside Tencent Mars and Tencent Mobile Framework), establishing that Tencent infrastructure spans networking, logging, and computer-vision functions within a Midea home-appliance app, none of which is disclosed to EU users under Art. 13.

Impact Analysis

C1 and C2 are both rated CRITICAL but for different reasons: C1 is a direct technical exposure, appliance commands traveling in cleartext over a network path an attacker can observe and alter. C2 is an accountability failure escalated by blast radius, a 122MB encrypted DEX that defeats independent verification while still leaking confirmed Tencent/WeChat infrastructure dependencies, at the scale of the world's largest household appliance manufacturer's EU-wide smart home install base. H1 through H3 compound the same pattern from different angles: location collection before consent, a plausible transfer path to Chinese infrastructure with no documented safeguard, and a permission set with no disclosed purpose. M1 closes the loop, a third confirmed Tencent SDK integration point.

What ties all six findings together procedurally is the same failure pattern documented elsewhere in this disclosure series: six messages, sent to two named, functioning addresses over 62 days, drew exactly one reply, a generic automated consumer-service acknowledgment in Chinese that does not engage a single one of the six technical findings.

The Complete Chain: Six Messages, One Automated Acknowledgment, Zero Substantive Replies

Step 1 – Disclosure sent: RFI-IRFOS sends the full findings report on 30 June 2026 to MideaDPO@midea.com and security@midea.com, CC press@midea.com, the Austrian Datenschutzbehoerde, and the EDPS, BCC the German BfDI and the Bavarian LDA, stating an embargo date of 28 September 2026.

Step 2 through 5 – Four follow-ups, identical outcome: RFI-IRFOS sends further messages on 6 July, 17 July, 27 July, and 9 August 2026, each restating the three direct questions and the days elapsed. No substantive reply is received at any point.

Step 6 – Fifth follow-up and one automated reply: On 31 August 2026, RFI-IRFOS sends a fifth follow-up, 62 days after the original disclosure. The same day, RFI-IRFOS receives one automated reply: a generic Chinese-language consumer-service acknowledgment confirming receipt and promising a response within 15 business days, describing account-deletion self-service steps, and not engaging any of the six technical findings. No further reply ever follows.

Step 7 – Embargo reached and passed: The embargo, stated once on 30 June 2026 and never revised, passes on 28 September 2026 with all six findings unaddressed.

Step 8 – Publication: This report publishes 19 days after the embargo date. Across 93 days and six messages sent to two functioning addresses, the correspondence record contains one automated, non-substantive acknowledgment and zero replies that engage the findings.

Data Protection – Article by Article

Art. 32(1)(b), Art. 32(1)(d) GDPR – Security of processing and testing the effectiveness of technical measures: C1's hardcoded Firebase keys and cleartext HTTP device-control endpoints leave appliance commands observable and alterable in transit.

Art. 5(2), Art. 32(1) GDPR – Accountability and security of processing: C2's 122MB VMP-encrypted DEX obstructs independent verification of lawfulness while confirmed Tencent/WeChat infrastructure dependencies remain detectable.

Art. 7, Art. 5(1)(b), Art. 5(1)(c) GDPR – Conditions for consent, purpose limitation, data minimisation: H1's five BOOT_COMPLETED receivers and background location access begin collection before any consent screen.

Art. 44-49 GDPR – Third-country transfers: H2's Tencent Mars/TMF infrastructure presents a plausible transfer path to China with no Art. 46 safeguard documented.

Art. 5(1)(c), Art. 25 GDPR – Data minimisation and data protection by design: H3's permission set (READ_LOGS, QUERY_ALL_PACKAGES, SYSTEM_ALERT_WINDOW, mandatory CAMERA) has no disclosed appliance-control purpose.

Art. 13 GDPR – Transparency: M1's Tencent QBar SDK integration is not disclosed to EU users.

Regulatory & Legal Landscape

Midea Group Co., Ltd. is headquartered in Foshan, China, and owns KUKA AG, the Augsburg, Germany-based industrial robotics manufacturer, which is why the German BfDI and the Bavarian LDA were BCC'd on the original disclosure alongside the Austrian Datenschutzbehoerde and the EDPS, both of whom remained in CC on every subsequent follow-up, informed under GDPR Art. 83(2)(b).

Fine exposure under GDPR: Art. 83(5) applies to the Art. 44-49 transfer issue in H2 and the accountability failure in C2, up to EUR 20,000,000 or 4% of total worldwide annual turnover, a figure that for the world's largest household appliance manufacturer by volume is measured against a substantial global turnover base. Art. 83(4) applies to the Art. 32, 7, 5, and 25 issues in C1, H1, H3, and M1, up to EUR 10,000,000 or 2% of total worldwide annual turnover. A company at this scale receiving six written disclosures over 62 days and responding with only one automated, non-substantive acknowledgment is itself a fact a regulator is likely to weigh alongside the six technical findings.

Indicators of Compromise

The following identifiers, SDK packages, and manifest declarations were extracted from the production APK via static analysis only. No Midea, Tencent, or KUKA servers, accounts, or infrastructure were probed.

```
C1 -- google_api_key: [REDACTED IN PUBLIC REPORT -- disclosed privately to Midea in R1
    ]
   google_crash_reporting_api_key: [REDACTED IN PUBLIC REPORT -- disclosed privately
    to Midea in R1]
   firebase_database_url: [REDACTED IN PUBLIC REPORT -- disclosed privately to Midea
    in R1]
   Cleartext hosts: air.midea.com, airtest.midea.com, weather.midea.com, pgp2p.midea.
    com:7781

C2 -- classes.dex: 122,002,416 bytes, 3 of ~50,000-100,000 classes decompilable
   Lcom/tencent/tmf/utils/GsonUtils; , Lcom/tencent/mars/xlog/Xlog; , com.tencent.mm

H1 -- android.permission.RECEIVE_BOOT_COMPLETED (x5 receivers),
    ACCESS_BACKGROUND_LOCATION

H2 -- Tencent Mars / Tencent Mobile Framework (residual strings, confirmed in use)

H3 -- android.permission.READ_LOGS, QUERY_ALL_PACKAGES, SYSTEM_ALERT_WINDOW, CAMERA (
    required=true)

M1 -- assets/qbar/detect_model.bin, srnet.bin (Tencent QBar computer-vision SDK)
```

Disclosure Timeline & Outcome

2026-06-30 Initial disclosure sent to MideaDPO@midea.com and security@midea.com, CC press@midea.com, Austrian DSB, EDPS, BCC German BfDI and Bavarian LDA. Embargo stated as 2026-09-28. REF MIDEA-MSMARTLIFE-2026.

2026-07-06, 2026-07-17, 2026-07-27, 2026-08-09 Four follow-up messages, each restating the six findings and the three direct questions. No substantive reply at any point.

2026-08-31 Fifth follow-up sent, 62 days since the original disclosure. The same day, one automated Chinese-language consumer-service acknowledgment is received; it does not engage any technical finding.

2026-09-28 Embargo date reached, as stated once on 2026-06-30 and never revised. Correspondence record: six RFI-IRFOS messages, one non-substantive automated reply.

2026-10-17 This report published, 19 days after the embargo date. All six findings confirmed unaddressed on the basis of the correspondence record.

Residual Risk & Recommendations

C1 – Immediate: migrate all device-control and telemetry endpoints to TLS, rotate the hard-coded Firebase keys, and bind any remaining client keys to certificate fingerprints.

C2 – Immediate: provide a verifiable account of what processing occurs within the encrypted DEX sufficient to meet Art. 5(2) accountability, and document the legal basis and safeguards for any data reaching Tencent infrastructure.

H1 – Near-term: gate location collection behind an explicit consent screen rather than allowing BOOT_COMPLETED receivers to initiate it.

H2 – Near-term: document an Art. 46 transfer safeguard for any data reaching Tencent Mars/TMF infrastructure, or remove the dependency for EU builds.

H3 – Near-term: remove or justify READ_LOGS, QUERY_ALL_PACKAGES, SYSTEM_ALERT_WINDOW, and the mandatory CAMERA requirement.

M1 – Near-term: disclose the Tencent QBar integration under Art. 13.

Across all findings: establish a monitored intake path for security and data-protection disclosures sent to MideaDPO@midea.com and security@midea.com that produces a substantive technical response, not only an automated consumer-service acknowledgment.

RFI-IRFOS security@rfi-irfos.com • rfi-irfos.com

ZVR 1015608684 • GISA 39261441 • UID ATU83405245 • Steuernummer 68 696/8736 • Elisabethinergasse 25/10, 8020 Graz, Austria All findings derive from static analysis of the published application using publicly available tooling. No Midea, Tencent, or KUKA servers, accounts, or infrastructure were probed. Technical evidence is archived under chain of custody and will be provided to regulatory authorities on request. Research conducted under ISO/IEC 29147, the freedom of scientific research (Art. 17 StGG) and GDPR Art. 89. REF MIDEA-MSMARTLIFE-2026.